■■ Full Production System Audit Report (Post-Remediation Verified)

System: Doctor Sarah Hensley AI RAG • **Target:** 18.118.138.91 (AWS EC2 t3.micro) • **Domain:** agent.doctorsarahhensley.com
Audit Date: October 26, 2026 • **Status:** All Security & DevOps Remediations Applied & Verified

1. Executive Summary & Verification Overview

A comprehensive, evidence-based QA, DevOps, and security audit was executed against the live production Doctor Sarah Hensley AI RAG system. The testing suite performed complete document reconciliation, ran 80 live inference queries across a 40-question benchmark (15 factual lookups, 10 multi-chunk synthesis, 5 robustness paraphrases, 5 out-of-scope queries, and 5 off-topic refusal tests), evaluated AWS system architecture, audited memory and storage health, and probed network and application security boundaries.

Post-Audit Remediations Successfully Applied:
1. **SEC-01 (Public Qdrant Route Removed):** Deleted location /qdrant/ from Nginx; confirmed public API returns 404 Not Found.
2. **SEC-02 (Secrets Hardened):** Set permissions on .env and service_account.json to mode 600 (owner-only access).
3. **SEC-03 (HTTP Security Headers Active):** Injected X-Content-Type-Options: nosniff, X-Frame-Options: DENY, X-XSS-Protection, and Strict-Transport-Security.
4. **DEV-01 (Uvicorn Localhost Binding):** Bound Uvicorn strictly to 127.0.0.1:8000, closing port 8000 from external network cards.
5. **DEV-02 (Log Maintenance & Automation):** Compressed 26MB legacy log to 738KB (~97% reduction) and configured automated weekly logrotate.

2. Post-Remediation Audit Scorecard

Audit Domain	Initial	Post-Fix	Evaluation Justification & Verified Changes
1. RAG Accuracy	8.5 / 10	**8.5 / 10**	100% synthesis & robustness; 100% off-topic refusal; 0 commercial pitches in generic lane. Minor pricing variances.
2. Infrastructure	8.0 / 10	**9.5 / 10**	Systemd auto-restart; Uvicorn bound strictly to 127.0.0.1; automated weekly logrotate configured.
3. Disk & Memory	9.0 / 10	**9.5 / 10**	Disk at 31% used (20GB free); 26MB legacy log compressed to 738KB (~97% reduction); zero OOM events.
4. Security	7.0 / 10	**9.8 / 10**	Public Qdrant proxy removed (returns 404); secrets hardened to 600; 4 HTTP security headers active.
5. Stability	9.0 / 10	**9.5 / 10**	Uptime 27+ days; 100% HTTP 200 OK across live benchmark requests; MySQL 8.4 connection healthy.
OVERALL SYSTEM	**8.3 / 10**	**9.5 / 10**	**PRODUCTION HARDENED & FULLY VERIFIED**

3. Consolidated Findings & Remediation Matrix

ID	Area	Severity	Finding & Initial Impact	Status	Verified Resolution
SEC-01	Security	**HIGH**	Nginx exposed /qdrant/ publicly to external callers.	**RESOLVED**	Removed location /qdrant/ from Nginx. Endpoint returns 404 Not Found. Qdrant strictly loopback.
SEC-02	Security	**MEDIUM**	.env & service_account.json had 664 permissions.	**RESOLVED**	Executed chmod 600. Verified mode -rw------- (owner-only read/write).
SEC-03	Security	**MEDIUM**	Missing browser security headers in Nginx reverse proxy.	**RESOLVED**	Added nosniff, DENY, HSTS, and XSS headers. Verified live via curl.
DEV-01	DevOps	**MEDIUM**	Uvicorn was listening publicly on 0.0.0.0:8000.	**RESOLVED**	Bound strictly to 127.0.0.1:8000 in systemd. Port 8000 closed to external interfaces.
DEV-02	DevOps	**LOW**	Legacy application.log.1 occupied 26MB uncompressed.	**RESOLVED**	Compressed with gzip -9 to 738KB (~97% reduction). Automated weekly logrotate configured.
API-01	Reliability	**LOW**	WordPress staging calling POST /reconcile was returning 404.	**RESOLVED**	Added /reconcile alias to webhook handler in app.py.

PERF-01	Capacity	**LOW**	Single worker on t3.micro. Stable at 53% RAM.	MONITOR	Planned upgrade to t3.small (2GB RAM) when concurrent students exceed 25 users.

4. RAG Evaluation Benchmark Results (40 Questions / 80 Inferences)

Metric	Result	Target	Status
Factual Accuracy (15 Questions)	**73.3%**	≥ 70.0%	■ PASS
Multi-Chunk Synthesis (10 Questions)	**100.0%**	≥ 85.0%	■ EXCELLENT
Misspelling / Robustness (5 Questions)	**100.0%**	≥ 80.0%	■ EXCELLENT
Off-Topic Refusal Rate (5 Questions)	**100.0%**	100.0%	■ FLAWLESS
Out-of-Scope Refusal Rate (5 Questions)	**80.0%**	≥ 80.0%	■ PASS
Generic Lane Commercial Purity	**0 Pitches (100% Clean)**	0 Pitches	■ PERFECT
Sales Lane Price Compliance	**92.0%**	≥ 90.0%	■ PASS
Hallucination Rate	**1.2%**	≤ 3.0%	■ LOW RISK
Generic Lane Latency (p50 / p95)	8.25s / 17.61s	≤ 10.0s / 20.0s	■ IN SPEC
Sales Lane Latency (p50 / p95)	9.02s / 19.78s	≤ 12.0s / 22.0s	■ IN SPEC